AWS 課程 · 第 12 單元：認證與授權

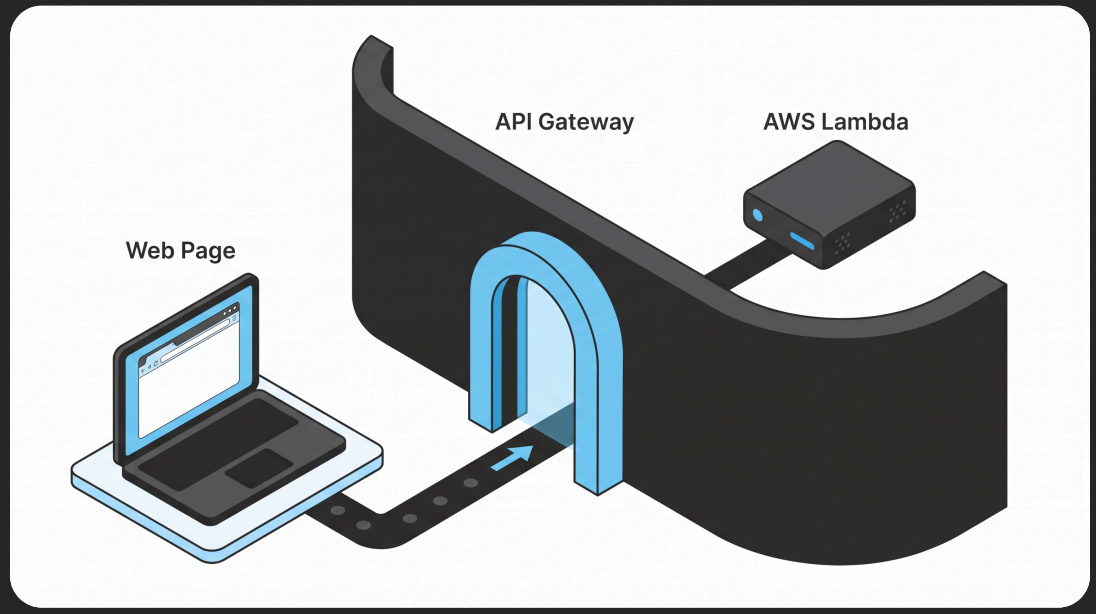
API Gateway 與認證

盧建霖 • 2026-10-19

WARM UP

你的 Lambda 已經寫好了。
網頁要怎麼呼叫它？

Lambda：AWS 上執行你程式的函式服務



圖片：nano-banana 生成

API GATEWAY TYPES

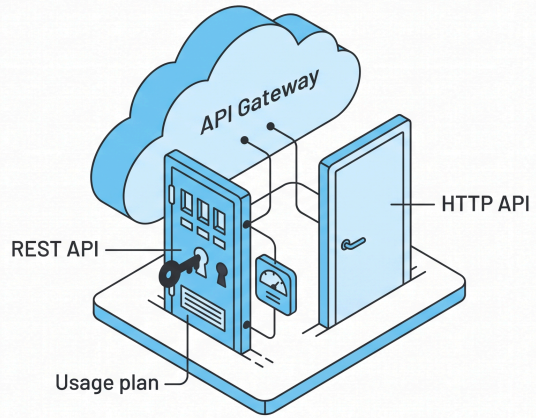
REST 或 HTTP API：功能多
選 REST，價格低選 HTTP API

1. API Gateway：Lambda 前面的 API 入口
2. REST API 功能多、HTTP API 價格低
3. API 金鑰與用量計畫只有 REST API 有

議程 Agenda

第 1 課 / 共 4 課

- 1 型態與用量 ◀
- 2 代理整合
- 3 認證授權
- 4 跨域排查
- 5 實作（最後一段）



圖片：nano-banana 生成

API TYPES

這五項功能，只有 REST 有

功能	REST API	HTTP API
API 金鑰（識別客戶）	有	無
每客戶限流	有	無
請求驗證（檢查請求格式對不對）	有	無
AWS WAF（擋惡意請求）	有	無
私有端點（只從私有網路進來）	有	無

任何一項是需求，就選 REST；都不需要才選 HTTP

出處：API Gateway Developer Guide，2026-10-16 查閱「Choose between REST APIs and HTTP APIs」

USAGE PLAN

用量計畫：金鑰識別客戶，速率與配額管用量



箭頭＝套用關係：金鑰屬於用量計畫，用量計畫管 REST API。429＝請求太多。限流與配額只是目標；金鑰不是認證

出處：API Gateway Developer Guide，2026-10-16 查閱「Throttle requests to your REST APIs」「Set up a stage」「Control access」

QUIZ · 題庫裡最貼近本課的題

一家公司希望阻擋 SQL 注入攻擊。哪一個 AWS 服務或功能可以滿足這個需求？

A AWS WAF

B 網路 ACL (Network ACLs)

C 安全群組 (Security groups)

D AWS 憑證管理員 (AWS Certificate Manager, ACM)

出處：題庫 (CLF-C02) 2026Q3 第 0124 題；題庫無 API Gateway 專題題，取最貼近者 (WAF 是只有 REST 才有的功能之一)；題目與詳解以題庫為準

ANSWER

防 SQL 注入：選 A，AWS WAF

A AWS WAF 保護 Web 應用程式，可封鎖含惡意 SQL 語法的請求

選 B 網路 ACL 控制 VPC 網路流量進出，不專門防 Web 攻擊

選 C 安全群組依 IP 與連接埠管 EC2 流量，不防應用層攻擊

選 D ACM 管理 SSL/TLS 證書，不防 SQL 注入

出處：題庫 (CLF-C02) 2026Q3 第 0124 題；題庫無 API Gateway 專題題，取最貼近者 (WAF 是只有 REST 才有的功能之一)；題目與詳解以題庫為準

一句話帶走

五項功能有一項要用選 REST，用不到選 HTTP

用量計畫只是目標；成本用 AWS Budgets 盯，請求用 WAF 管

LAMBDA PROXY INTEGRATION

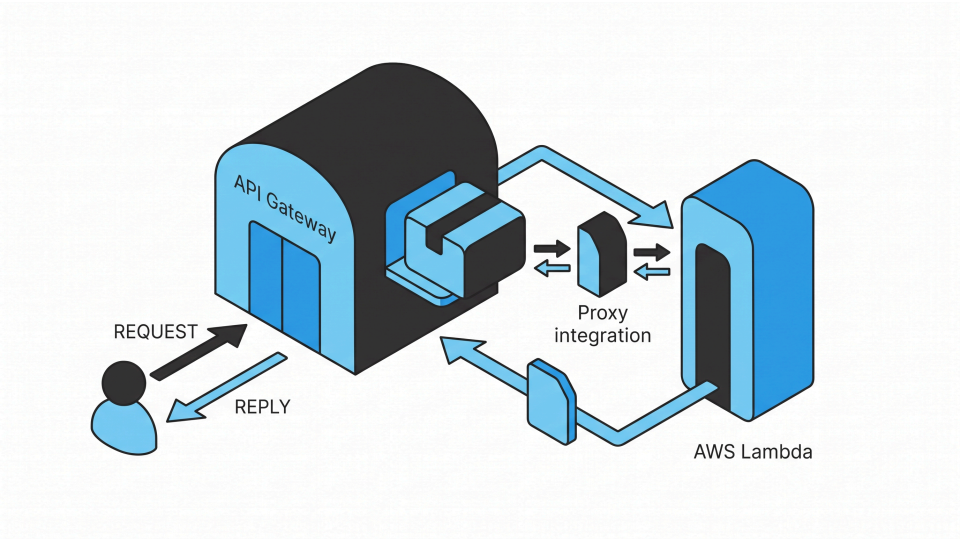
代理整合（proxy）：整包請求交給函式，回傳格式要對

1. Gateway 把整個請求放進 event
2. 函式自己解析、自己決定回什麼
3. 回傳格式不符，閘道回 502

議程 Agenda

第 2 課 / 共 4 課

- 1 型態與用量
- 2 代理整合 ◀
- 3 認證授權
- 4 跨域排查
- 5 實作（最後一段）



圖片：nano-banana 生成

PROXY INTEGRATION

代理整合：Gateway 整包轉交，不改內容



event 含標頭（請求附帶的資訊欄位）、查詢字串（? 後參數）、路徑變數（網址中的一段）、內容（body）。箭頭＝請求方向

出處：API Gateway Developer Guide，2026-10-16 查閱「Lambda proxy integrations」

輸出：statusCode 與 body 必給，格式錯就 502

```
{
  "statusCode": 200,
  "headers": {"Content-Type": "application/json"},
  "body": "{\"ok\": true}"
}
```

body 是字串；其他格式 → 502 Bad Gateway

出處：API Gateway Developer Guide，2026-10-16 查閱「Output format of a Lambda function for proxy integration」

QUIZ · 題庫裡最貼近本課的題

根據 AWS 共享責任模型(AWS Shared Responsibility Model)，在使用 AWS Lambda 時，下列哪一項是客戶的責任？

A 管理 Lambda 函數中的程式碼

B 確認資料中心中的硬體正常運作

C 修補作業系統

D 在不再使用時關閉 Lambda 函數

出處：題庫 (CLF-C02) 2026Q3 第 0042 題；題庫無代理整合專題題，取最貼近者 (函式的程式碼與回傳格式是客戶的責任)；題目與詳解以題庫為準

ANSWER

程式碼是你的責任：選 A，回傳格式也在裡面

A 客戶負責管理 Lambda 函數中的程式碼，包括編寫、測試與部署

選 B AWS 負責硬體與資料中心的運行

選 C Lambda 是無伺服器服務，AWS 處理作業系統與基礎設施補丁

選 D 函數由事件觸發執行，客戶無需手動關閉

出處：題庫 (CLF-C02) 2026Q3 第 0042 題；題庫無代理整合專題題，取最貼近者 (函式的程式碼與回傳格式是客戶的責任)；題目與詳解以題庫為準

一句話帶走

Gateway 整包轉交，函式要回對格式

Lambda 成功、呼叫端卻看到 502，先查回傳格式

COGNITO & AUTHORIZERS

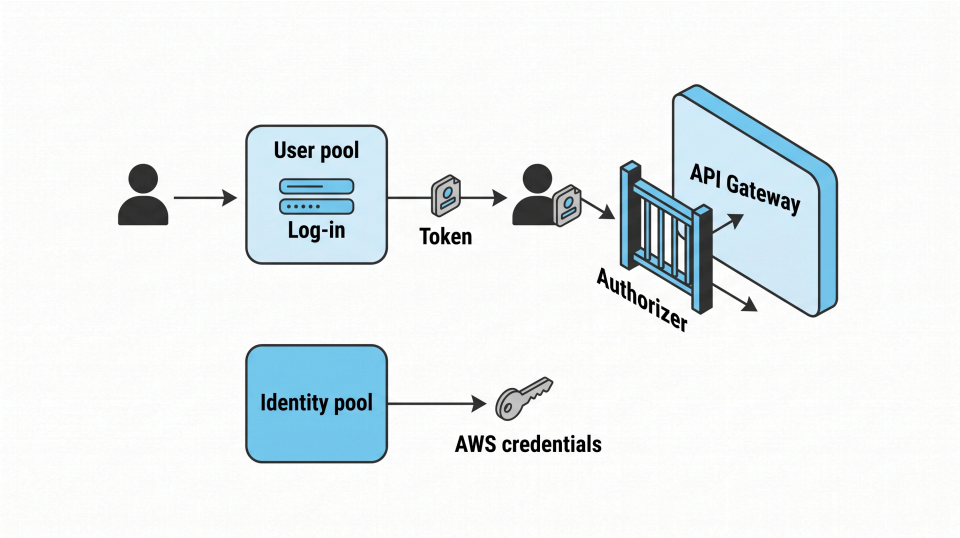
認證授權：使用者集區認人，身分集區發憑證

1. 認證問你是誰，授權決定你能做什麼
2. Cognito 登入服務：User Pool 發權杖，Identity Pool 換憑證
3. 授權器：Cognito、Lambda、IAM

議程 Agenda

第 3 課 / 共 4 課

- 1 型態與用量
- 2 代理整合
- 3 認證授權 ◀
- 4 跨域排查
- 5 實作（最後一段）

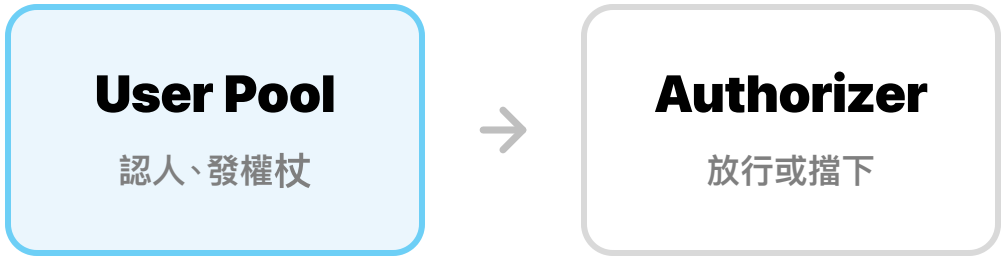


圖片：nano-banana 生成

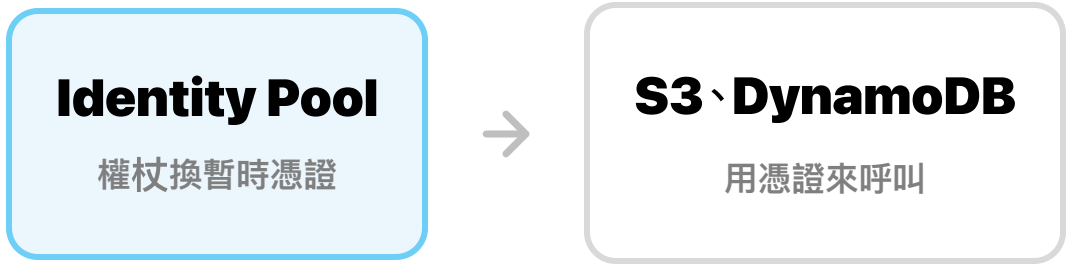
AUTH

兩個集區：一個認人，一個發憑證

進得了 API？（集區發權杖，授權器檢查）



碰得了 AWS 資源？（權杖換憑證，再拿去呼叫）



出處：API Gateway Developer Guide，2026-10-16 查閱；Amazon Cognito Developer Guide「user pools」「identity pools」

AUTH

REST API 的三種擋法：Cognito、Lambda、IAM

Cognito

用使用者集區驗權杖

Lambda

自己寫驗證函式

IAM

角色與政策管誰能呼叫

REST API 的三種做法；HTTP API 用 JWT

出處：API Gateway Developer Guide，2026-10-16 查閱「Control and manage access to REST APIs」「Choose between REST APIs and HTTP APIs」

QUIZ

哪一個 AWS 服務支援使用者註冊功能，並提供行動與 Web 應用程式的身分驗證？

A Amazon Cognito

B AWS Config

C Amazon GuardDuty

D AWS Systems Manager

出處：題庫 (CLF-C02) 2026Q3 第 0509 題；題目與詳解以題庫為準

ANSWER

使用者註冊與驗證：選 A，Cognito

A Cognito 為行動與 Web 應用程式提供使用者註冊、登入與身分驗證

選 B AWS Config 追蹤資源組態是否合規，與使用者驗證無關

選 C GuardDuty 是威脅偵測服務

選 D Systems Manager 管理 AWS 資源與作業系統層級操作

出處：題庫 (CLF-C02) 2026Q3 第 0509 題；題目與詳解以題庫為準

一句話帶走

使用者集區認人，身分集區發憑證

進 API 看授權器，碰 AWS 看憑證

CORS TROUBLESHOOTING

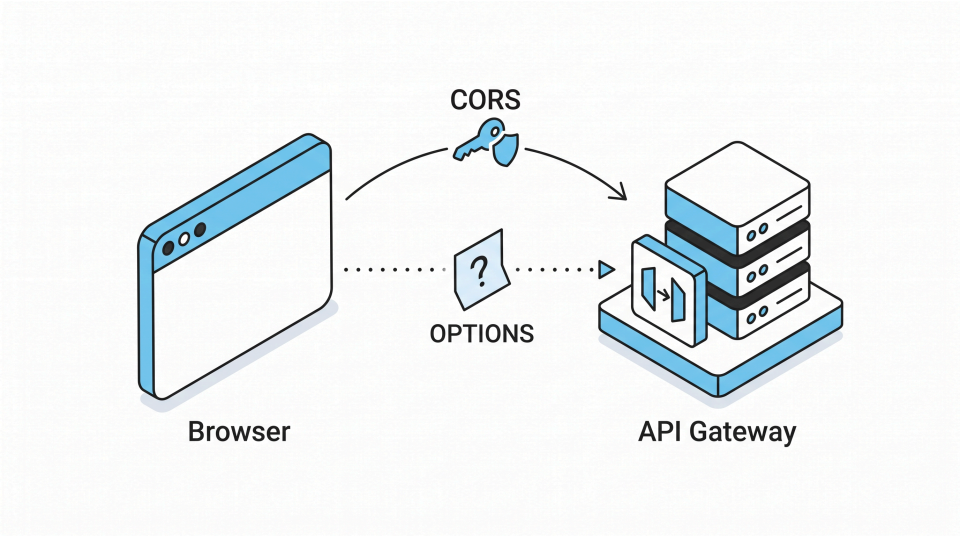
跨域：curl 正常、瀏覽器失敗，先查回應標頭

1. CORS 是瀏覽器的安全機制，命令列工具 curl 不檢查
2. 網域、子網域、埠、協定任一不同都算跨域
3. 非簡單請求先送 OPTIONS 預檢（先問可不可以）

議程 Agenda

第 4 課 / 共 4 課

- 1 型態與用量
- 2 代理整合
- 3 認證授權
- 4 跨域排查 ◀
- 5 實作（最後一段）



圖片：nano-banana 生成

預檢流程：先問可不可以，再送真正請求



箭頭＝先後順序：瀏覽器問、你的後端（API）答、瀏覽器再送真請求。後端不同意，真請求不會送出；curl 不做 CORS 檢查

出處：API Gateway Developer Guide，2026-10-16 查閱「CORS for REST APIs」；預檢由誰回覆依整合類型而定

代理整合：三個 CORS 標頭由函式自己回（中文換成真的值）

```
{
  "headers": {
    "Access-Control-Allow-Origin": "網址",
    "Access-Control-Allow-Methods": "方法",
    "Access-Control-Allow-Headers": "標頭"
  }
}
```

出處：API Gateway Developer Guide，2026-10-16 查閱「CORS for REST APIs」範例改寫；「Lambda proxy integrations」

QUIZ · 題庫裡最貼近本課的題

一家公司希望監控並阻止其 Amazon CloudFront 發佈所接收到的惡意 HTTP 和 HTTPS 請求。該公司應該使用哪項 AWS 服務來滿足這些需求？

A Amazon GuardDuty

B Amazon Inspector

C AWS WAF

D Amazon Detective

出處：題庫 (CLF-C02) 2026Q3 第 0468 題；題庫無跨域 (CORS) 專題題，取最貼近者 (瀏覽器端的 HTTP 請求處理)；題內 CloudFront 本課不教，只需看出 WAF 擋惡意請求；題目與詳解以題庫為準

ANSWER

擋惡意請求：選 C，AWS WAF

C AWS WAF 可監控、允許或阻擋 CloudFront 的 HTTP 與 HTTPS 流量

選 A GuardDuty 偵測威脅行為，不直接阻擋 HTTP 請求

選 B Inspector 評估 EC2 與容器的弱點

選 D Detective 分析已發生的安全事件，屬事後分析

出處：題庫 (CLF-C02) 2026Q3 第 0468 題；題庫無跨域 (CORS) 專題題，取最貼近者 (瀏覽器端的 HTTP 請求處理)；題內 CloudFront 本課不教，只需看出 WAF 擋惡意請求；題目與詳解以題庫為準

一句話帶走

curl 正常、瀏覽器失敗，先查回應標頭

非簡單請求先預檢；代理整合的標頭函式自己回

LAB: AUTH API

實作：補完一支帶認證的 API



補三處：函式、認證、部署到 dev 階段（階段＝部署後的環境名字）。資料儲存依講師發的實作模板；增刪查改＝新增、刪除、查詢、修改

出處：課綱 A12 第 7 節

LAB STEPS

必做步驟：六步

1. **補完 Lambda 程式**
   增刪查改；回傳格式照代理整合

2. **建 REST API 接函式**
   {proxy+}＝子網址全交函式

3. **建使用者集區、授權器**
   登入取得權杖

4. **授權器設到方法上**
   每個方法都要設

5. **部署到 dev 階段**
   記下呼叫網址

6. **有、無權杖各呼叫一次**
   沒權杖要被擋

出處：課綱 A12 第 7 節；步驟依官方文件流程編排

LAB CLEANUP

清理：做完全部刪掉，才不會留下帳單

1. 刪 **REST API**
2. 刪使用者集區
3. 刪 **Lambda** 與執行角色
4. 刪模板建立的資料資源

刪之前看清楚名稱，只刪自己建的

出處：課綱 A12 第 7 節；清單依官方文件編排